At ACME, the governance framework links the three systems that influence authorization decisions: engineering, operations, and governance itself. Engineering develops and deploys new capabilities; operations monitors how those capabilities perform in production; and governance reviews, interprets, and formalizes lessons learned. Without these feedback loops, policies can drift from their original intent, incidents may recur, and institutional knowledge can be lost.

ACME realized this integration was crucial after a production incident—caused by an outdated access rule—showed that policy reviews and operational data existed in separate systems. Engineering managed policies through version control and CI/CD, while operations tracked incidents via a ticketing system that lacked connection to governance. Connecting these systems formed a continuous cycle: Incidents prompted reviews, reviews led to updates, and updates were tested and deployed through the same disciplined process described earlier. Governance became not a separate bureaucracy but a coordinating function that united technical assurance with organizational accountability.

14.3.1 The structure of governance

A governance framework establishes the organizational structure for managing authorization. It outlines the roles, artifacts, and processes that keep policies reliable and understandable, ensuring that authorization stays aligned with organizational goals even as technology and business environments change.

At ACME, governance operates under a federated model. Central standards and templates specify how policies are created, reviewed, and tested, but daily management is handled by individual product teams. Figure 14.4 shows how a federated governance model addresses the policy drift illustrated earlier in figure 14.1. Rather than centralize policy ownership, governance normalizes how intent is translated into policy through shared standards, templates, and review processes. Teams continue to manage their own policies, but those policies are better aligned with organizational intent.